# Document de tests et de validation - MiniShop

Deuxième document du rendu (barème iii : l'application **et** les deux documents ; pénalité « manque le document de test et de validation » : **-3 points**). Complément du §15 du cahier des charges et compagnon des **suites détaillées de recette manuelle par cas d'utilisation** ([13-fiches-recette-uc.md](13-fiches-recette-uc.md) et [13-suivi-recette-uc.csv](13-suivi-recette-uc.csv)) : dispositif, cas détaillés, exécution automatisée et protocole manuel, registre d'anomalies, PV de recette et traçabilité.

**Mise à jour du 23/10/2026** : le plan de recette et de validation ci-dessous est intégralement aligné sur l'application livrée :

• messages humains en français et en anglais sans aucun code technique brut (`RB03_...`, `SQLSTATE`, `STOCK_INSUFFISANT`) ;

• confirmations explicites en deux étapes fonctionnant **même sans JavaScript** avant toute action définitive (annulation client, suppression produit/catégorie, annulation administrateur avec retour de stock avant expédition et sans retour automatique sur commande `EXPEDIEE`, garde SQL `ANNULATION_VIA_PARCOURS_DEDIE`) et conservation de l'historique des lignes après annulation ;

• mode d'ajustement de stock par défaut non destructif (`DELTA` « Ajouter / retirer ») et refus strict des doublons de catégories ;

• préférences personnelles sur `/preferences` accessibles sans compte (`localStorage` seul, aucun cookie de suivi) : choix manuel ou géolocalisation navigateur locale sans tiers (`public/js/tz-lookup.js` CC0), traduction complète FR <-> EN des 48 vues et du panier AJAX (`public/js/i18n-en.js`, `public/js/panier.js`), stockage UTC de bout en bout et affichage/filtrage selon le fuseau local choisi ;

• compatibilité responsive à 320, 375, 768 et 1440 px avec tableaux administrateur et clients repliés en cartes mobiles étiquetées (`data-label`) et double implémentation décorative/informative des visuels produits ;

• mentions légales de la maquette étudiante conformes à l'article 6, III, 2 de la LCEN (co-éditeurs **Johan Polsinelli** et **Chahd Gouiaa**, hébergeur pédagogique IUT Nice Côte d'Azur `linserv-info-01.campus.unice.fr`), transparence RGPD de la maquette scolaire et outils CLI de conservation/purge (`24 mois` comptes sans commande, `12 mois` contact, `6 mois` journaux, `30 jours` sauvegardes dédiées).

Aucun résultat d'exécution humaine sur navigateur réel ou serveur LineServ n'est inventé : la colonne « Statut » distingue strictement ce qui est **exécuté automatiquement en CI** (15 jobs verts, y compris l'intégralité des contrôles responsive 320/375/1440 px sous Chromium) de ce qui **reste à dérouler manuellement** (`[!]`, et `NON JOUÉ` sur les 200 entrées de [13-suivi-recette-uc.csv](13-suivi-recette-uc.csv) - les campagnes responsive multi-largeurs ayant été volontairement retirées des suites manuelles car trop longues à jouer à la main). La campagne manuelle prévue se déroule sur la base réellement utilisée par l'application de production LineServ pendant une fenêtre pré-démo, puis cette même base doit être restaurée à l'état de démonstration avant la démo ; rien de cela n'a été effectué. `minishop_test` reste exclusivement

une base temporaire des tests automatisés GitHub CI, pas une cible de recette manuelle.

# 1. Dispositif

| Élément | Valeur |
|---|---|
| Environnement automatisé CI | Linux (Debian 13 / Ubuntu), PHP 8.2 et 8.5, MariaDB 11.8 et MySQL 8.0, Apache 2.4 / routeur de développement, Playwright Chromium (320, 375 et 1440 px, FR et EN, avec et sans JS) |
| Cible de la recette manuelle | Instance LineServ et base de production réellement configurée pour l'application (`DB_NAME` à confirmer dans la configuration privée) ; campagne pré-démo, puis restauration obligatoire de cette même base à l'état de démonstration |
| Jeu de données automatisé | seed `sql/01` + commandes de démo `sql/04` : 4 catégories, 36 produits, 3 clients (`alice`, `bruno`, `carla`), 1 admin `SUPER`, 4 commandes ; base temporaire `minishop_test` créée/supprimée uniquement pour les tests SQL automatisés en CI |
| Outillage automatisé | `scripts/run-all-tests.mjs` & `scripts/run-all-tests.php`, `scripts/strict_types_lint.php` (158 fichiers), `tests/security/controles.sh` (10 contrôles + auto-test), PHPUnit 11 (9 classes, 50 tests), 42 suites PHP, `scripts/run_sql_tests.sh` + `tests/php/sql_integration.php` (29 tests SQL + étape 6 PDO) + `tests/php/migration_mariadb_test.php`, `tests/node/preferences_test.mjs` (48 vues FR<->EN + AJAX), `scripts/wasm-e2e.mjs` (338 contrôles HTTP isolés), 23 parcours `scripts/ui-e2e-*.mjs`, `tests/node/responsive_navigateur.mjs`, `scripts/verifier_fiches_uc.py` |
| Suites de recette manuelle | [`docs/13-fiches-recette-uc.md`](13-fiches-recette-uc.md) (**164 scénarios** sur UC-01..UC-14 + §15 transversal et **36 couples** de transition `RB-11`, hors responsive multi-largeurs délégué à la CI) et journal vierge [`docs/13-suivi-recette-uc.csv`](13-suivi-recette-uc.csv) (**200 lignes `NON JOUÉ`**), complétés par [`docs/14-guide-lineserv.md`](14-guide-lineserv.md) |
| Chaîne CI | GitHub Actions : `.github/workflows/ci.yml` (**15 jobs** lors du dernier run cité) ; aucune configuration GitLab CI dans le périmètre courant |
| Entrée en recette | pré-conditions `PRÉ-1`...`PRÉ-6` du CDC §11.3 ; confirmation de la cible de production LineServ, accès limité et données synthétiques ; sauvegarde restaurable de l'état de démo avant les écritures ; préférences `/preferences` réinitialisées (`Français`, `Europe/Paris`) |
| Critère de recette | 0 anomalie bloquante (perte de données, stock faux, contournement de sécurité) **et** 0 anomalie majeure (fonctionnalité du sujet indisponible) ; les limites propres à la maquette scolaire sont explicitement documentées |
| Rejouabilité | chaque test SQL journalise dans `tests/sql/out/<ID>.log` ; aucun test automatisé ne touche `data/minishop/*.json` ni la base applicative (magasins temporaires dédiés vérifiés par `scripts/e2e_isolation.mjs`) |

# 2. Tests de règles de gestion (base de données) - **exécutés**

Tests SQL **automatisés uniquement** : `./scripts/run_sql_tests.sh` ou `php tests/php/sql_integration.php` (base temporaire `minishop_test` créée puis supprimée par le harnais ; manifeste `tests/sql/manifest.txt`, fixture d'état avant chaque scénario). Ces commandes ne sont pas à lancer sur LineServ et ne désignent pas la base des tests manuels.

**Résultat vérifié en CI (MySQL 8.0 et MariaDB 11.8) : 29 tests / 29 conformes**, complétés par l'**étape 6 d'intégration PDO** (`sp_cancel_order` avec conservation des lignes et restitution unique du stock, garde `ANNULATION_VIA_PARCOURS_DEDIE` sur `sp_update_order_status`, annulation administrateur d'une commande `EXPEDIEE` sans retour de stock, session PDO forcée en UTC `+00:00`, filtrage UTC de `revenueReport` et `RetentionComptes` sur `SqlStore`) ainsi que par `tests/php/migration_mariadb_test.php` sur schémas antérieurs. 15 de ces tests contournent volontairement l'application (`INSERT`/`UPDATE`/`DELETE` directs) : la conformité prouve que les règles tiennent dans le SGBD lui-même.

| Test | Règle | Vérification - attendu | Résultat |
|---|---|---|---|
| T-01 | RB-02 | prix HT = 0 refusé par le `CHECK ck_produit_prix` - refus par la base attendu | **conforme** |
| T-02 | RB-03 | stock négatif refusé (`CHECK`) en écriture directe - refus par la base attendu | **conforme** |
| T-03 | RB-03 | stock négatif refusé par `trg_produit_regles` - refus par la base attendu | **conforme** |
| T-04 | RB-01 | e-mail client dupliqué (contrainte `uk_client_email`) - refus par la base attendu | **conforme** |
| T-05 | RB-12 | `sp_create_account` refuse un mot de passe non haché (60 car. bcrypt requis) - refus par la base attendu | **conforme** |
| T-06 | RB-05 | quantité = 0 refusée par `sp_add_order_line` - refus par la base attendu | **conforme** |
| T-07 | RB-05 | quantité = 0 refusée par le `CHECK ck_ligne_quantite` - refus par la base attendu | **conforme** |
| T-08 | RB-18 | stock insuffisant : `trg_ligne_controle_insert` bloque - refus par la base attendu | **conforme** |
| T-09 | RB-18 | stock insuffisant : code de retour `STOCK_INSUFFISANT` de la procédure - exécution contrôlée attendue | **conforme** |
| T-10 | RB-15 | `montant_total` non saisissable (`trg_commande_montant`) - refus par la base attendu | **conforme** |
| T-11 | RB-06 | `prix_unitaire` et quantité d'une ligne non modifiables (immutabilité) - refus par la base attendu | **conforme** |
| T-12 | RB-11 | transition `EN_PREPARATION -> BROUILLON` interdite - refus par la base attendu | **conforme** |
| T-13 | RB-11 | transition `EXPEDIEE -> BROUILLON` interdite - refus par la base attendu | **conforme** |
| T-14 | RB-14 | suppression d'une catégorie non vide - refus par la base attendu | **conforme** |
| T-15 | RB-14 | suppression physique d'un produit déjà commandé - refus par la base attendu | **conforme** |
| T-16 | RB-04 | validation d'une commande sans ligne - refus par la base attendu | **conforme** |
| T-17 | RB-10 | commande rattachée à un client inexistant (trigger + FK) - refus par la base attendu | **conforme** |

| | | | |
|---|---|---|---|
| T-18 | SEC-08 | `sp_confirm_order` refuse l'accès à la commande d'un autre client (`ACCES_NON_AUTORISE`) - refus attendu | **conforme** |
| T-19 | RB-03 | `sp_adjust_stock` refuse le passage en négatif (paramètre `OUT`) - exécution contrôlée attendue | **conforme** |
| T-20 | RB-09 | produit déjà commandé : `sp_delete_product` bascule `visible = 0` sans suppression - exécution attendue | **conforme** |
| T-21 | RB-18 | annulation avant expédition : stock restauré exactement une fois, lignes conservées - exécution attendue | **conforme** |
| T-22 | RB-11 | historique des statuts écrit automatiquement par `trg_history_statut` sans doublon - exécution attendue | **conforme** |
| T-23 | RB-06 | le prix unitaire figé de la ligne survit à une hausse tarifaire ultérieure - exécution attendue | **conforme** |
| T-24 | RB-04 | suppression d'une commande `BROUILLON` vide autorisée - exécution attendue | **conforme** |
| T-25 | EF-VIS-02 | recherche + filtres + exclusion des produits masqués (`sp_search_products`) - exécution attendue | **conforme** |
| T-26 | EF-ADM-05 | alertes de stock (`RUPTURE` / `TRES_BAS`) calculées sans conflit de collation - exécution attendue | **conforme** |
| T-27 | EF-VIS-01 | les 3 vues (`v_catalogue`, `v_etat_stock`, `v_commandes_client`) existent et sont cohérentes - exécution attendue | **conforme** |
| T-28 | ENF-14 | frais de port calculés avant validation, figés à la validation et non saisissables manuellement - refus d'altération attendu | **conforme** |
| T-29 | ENF-16 | erreur en cours de commande : rollback intégral, aucune commande ni décrémentation partielle - exécution attendue | **conforme** |

## 3. Tests fonctionnels (recette de l'application - `F-00` à `F-56`)

Les gestes manuels `[!]` se font sur l'application LineServ reliée à sa base de production, pendant la fenêtre pré-démo autorisée et avec des données synthétiques. Après la campagne, restaurer cette même base à l'état de démonstration selon [`14-guide-lineserv.md`](14-guide-lineserv.md). La base `minishop_test` ne sert qu'aux tests automatisés en CI.

Lecture de la colonne **Statut** :

- « **automatisé (...)** » : assertions exécutées automatiquement par `scripts/run-all-tests.mjs` et les 15 jobs CI (les vérifications responsive 320/375/1440 px et cartes mobiles `data-label` sont couvertes uniquement en automatisé par `responsive_contract.php` et `responsive_navigateur.mjs`, hors suites manuelles) ;
- « **automatisé (...) + test navigateur réel `[!]`** » : logique et DOM prouvés automatiquement en JSDOM/Chromium, comportement natif de l'interface navigateur (invite de permission de géolocalisation, stockage local, relecture linguistique) restant à constater humainement (`NON JOUÉ` dans [`13-suivi-recette-uc.csv`](13-suivi-recette-uc.csv)) ;
- « **manuel à rejouer `[!]`** » : scénario d'installation ou d'exploitation humaine sur poste cible / LineServ.

| I | Titre | Préconditions | Étapes | Résultats attend | Règles / ENF | Statut |
|---|---|---|---|---|---|---|

| | | | | | | |
|---|---|---|---|---|---|---|
| F-00 | Installation de bout en bout | base vierge, dépôt cloné, `.env` configuré | copier `.env.example` vers `.env`, exécuter `./run.sh --db` (ou `php scripts/db_init.php --switch`) puis `./run.sh` | 8 tables, 3 vues, 1 fonction, 17 procédures, 16 triggers, 36 produits, 3 clients ; accueil en HTTP 200 ; durée à chronométrer (<= 15 min) | ENF-13 | automatisé (`db_init` / CI SQL) + chronométrage manuel `[!]` |
| F | Liste des catégories | seed chargé | `GET /categories` | 4 catégories centrées avec icônes SVG propres et compteurs limités aux produits visibles | RB-08, RB-19 | automatisé (`wasm-e2e`, `css_contract`) |
| F-02 | Recherche simple | seed chargé | `GET /recherche?q=casque` | résultats correspondants visibles uniquement ; mot-clé conservé dans l'URL ; aucune trace SQL | RB-19, SEC-01 | automatisé (`catalogue_stock_test`, `wasm-e2e`) |
| F | Filtres cumulés + tri | seed chargé | `GET /catalogue?cat=2&prix_max=160&stock=1&tri=prix_asc`, copier l'URL en session vierge | produits visibles filtrés et triés par prix TTC croissant ; l'URL collée reproduit exactement la même liste | RB-19, ENF-04/05 | automatisé (`catalogue_filtres_test`, `wasm-e2e`) |
| F-04 | Pagination et bornes | seed chargé | `GET /catalogue?page=2`, `page=999`, `par_page=500` | pagination cohérente ; page hors plage vide avec retour page 1 sans erreur ; plafond serveur de 60 par page | ENF-04 | automatisé (`catalogue_stock_test`, `wasm-e2e`) |
| F | Fiche produit avec prix TTC | `CASQ-005` (129,0 EUR HT, TVA 20 %) | `GET /produit/casque-sans-fil-aura` | 154,80 EUR TTC (TVA incluse), état « Disponible », `max` calé sur le stock réel, visuel informatif indicatif | RB-02, RB-16, ENF-14 | automatisé (`fiche_produit_test`, `ui-e2e-produit`) |
| F-06 | Inscription valide | session visiteur | `POST /inscription` (données fictives conformes + CGV) | compte créé, session ouverte sur `/compte`, hash bcrypt de 60 caractères en base | RB-01, RB-12 | automatisé (`features_test`, `wasm-e2e`) |
| F | Inscription refusée (e-mail existant) | `client-test@example.test` existe | `POST /inscription` avec le même e-mail | message humain « Cet email est déjà utilisé. », saisies non sensibles conservées, aucun doublon créé | RB-01 | automatisé (`inscription_erreurs_test`, `wasm-e2e`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F-08 | Connexion : messages indifférenciés | - | `POST /connexion` avec (a) e-mail inconnu (b) e-mail connu + mauvais mot de passe | réponse strictement identique (« Email ou mot de passe erroné. »), aucun indice d'existence du compte | RB-12, SEC-04 | automatisé (`features_test`, `wasm-e2e`) |
| F | Panier visiteur conservé jusqu'à connexion | session visiteur | ajouter un produit, demander `/commande/valide`, se connecter | panier conservé en session ; redirection vers `/connexion` puis reprise du parcours client | ENF-07, SEC-0 | automatisé (`wasm-e2e`) |
| F-10 | Modification du profil | client connecté | `POST /compte` (nouveau téléphone et adresse structurée, e-mail inchangé) | profil mis à jour sans faux refus d'unicité sur son propre e-mail | RB-01 | automatisé (`adresse_livraison_test`, `wasm-e2e`) |
| F | Changement de mo de passe | client connecté | `POST /compte/mot-de-passe` (ancien exact, nouveau >= 8 car.) | nouveau hash enregistré ; ancien mot de passe rejeté à la reconnexion | RB-12, SEC-04 | automatisé (`features_test`, `wasm-e2e`) |
| F-12 | Ajout au panier avec plafond de stock | `MICRO-007` stock 2 | demander une quantité de 5 (formulaire ou `/api/panier/ajouter`) | refus clair sans code technique, panier plafonné/inchangé, stock en base intact | RB-18 | automatisé (`catalogue_stock_test`, `ui-e2e-panier`) |
| F | Repli complet sans JavaScript | JS désactivé dans le navigateur | ajouter au panier, modifier quantité, retirer, valider commande, confirmer annulation | 100 % des parcours fonctionnent en POST/GET serveur classiques sans JS | ENF-07 | automatisé (`wasm-e2e`, `responsive_navigateur` sans JS) |
| F-14 | Retrait idempotent d'une ligne | panier à 2 articles | retirer le 1er article, puis rejouer le même retrait | récapitulatif recalculé côté serveur ; second retrait absorbé sans erreur | ENF-16 | automatisé (`unit_tests`, `wasm-e2e`) |
| F | Total calculé exclusivement côté serveur | panier `{CASQ-005 × 2, CABLE-009 × 1}` | `GET /panier`, puis `POST /panier/quantite` en injectant `prix_unitaire=0.01` | sous-total, TVA, port et total TTC calculés par le serveur ; champ `prix_unitaire` client ignoré | RB-06, RB-15, RB-16 | automatisé (`wasm-e2e`) |
| F-16 | Validation complète d'une commande | panier `{CASQ-005 × 2}`, client connecté | adresse pré-remplie -> récapitulatif -> confirmer | commande `CMDAAAA-NNNNNN` créée, montant 309,60 EUR (port offert >= 80 EUR), stock décrémenté de 2, historique initial écrit, panier vidé | RB-04, RB-06, RB-11, RB-15, RB-18 | automatisé (`wasm-e2e`, `ui-e2e-valider`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F | Prix unitaire figé après hausse tarifaire | commande F-16 validée ; admin passe `CASQ-005` 199,00 EUR HT | rouvrir `/mes-commandes/{id}` côté client | la ligne commandé affiche toujours 154,80 EUR TTC tandis que le catalogue affiche 238,80 EUR TTC | RB-06, RB-16 | automatisé (`run_tests`, `wasm-e2e`, `T-23`) |
| F-18 | Rollback intégral sur stock insuffisant (2e ligne) | `MICRO-007` stock 2 ; panier `{CASQ-005 × 1, MICRO-007 × 3}` | soumettre `/comma de/valider` | refus humain « Stock insuffisant pour cette quantité. », aucune commande créée, stock de `CASQ-005` intact, panier conservé | RB-04, RB-18, ENF-16 | automatisé (`features_test`, `wasm-e2e`, `T-29`) |
| F | Historique des commandes client | client ayant 2 commandes dont 1 annulée | `GET /mes-commandes` | les 2 commandes remontent avec date locale, badge de statut et montant ; la commande annulée reste consultable | RB-10, RB-11 | automatisé (`mes_commandes_tableau_test`, `ui-e2e-mes-commandes`) |
| F-20 | Isolation des commandes entre clients (anti-IDOR) | `bruno` connecté | `GET /mes-commandes/{id_commande_alice}` | réponse HTTP **404** (jamais 403), aucune donnée d'`alice` divulguée | SEC-08, ENF-12 | automatisé (`wasm-e2e`, `T-18`) |
| F | Annulation client en 2 étapes et conservation de l'historique | commande `EN_PREPARATION` (`SAC-008` × 2) | 1) `GET /mes-commandes/{id}/annulation/confirmation` (sans effet au rechargement) ; 2) `POST /mes-commandes/{id}/annulation` | statut `ANNULEE`, **lignes d'origine conservées en historique**, `Total avant annulation` affiché, total et port soldés à `0,00 EUR`, stock recrédité **exactement une fois**, trace `CLIENT` ajoutée | RB-09, RB-11, RB-18 | automatisé (`annulation_historique_test`, `ui-e2e-annulation`, `T-21`) |
| F-22 | Création de produit par l'administration | session admin | `POST /admin/produit/nouveau` (HT 10,00 EUR, TVA 20 %, stock 5, Audio) | produit créé, `prix_ttc` = 12,00 EUR calculé, visible immédiatement côté catalogue et nouveautés | RB-02, RB-16 | automatisé (`features_test`, `wasm-e2e`) |
| F | Suppression en 2 étapes et masquag d'un produit commandé | produit référencé dans >= 1 comma | `GET /admin/produts/{id}/suppression/confirmation` puis `POST /admin/produits/{id}/suppression` | passage à `visible = 0` sans suppression physique ; disparition du catalogue public, commandes historiques intactes | RB-09, RB-14, RB-17 | automatisé (`actions_destructrices_test`, `wasm-e2e`, `T-20`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F-24 | Pages d'information, légales et préférences | - | `GET /a-propos`, `/aide`, `/contact`, `/mentions-legales` (`/mentions`), `/cgv`, `/cgu`, `/livraison`, `/retractation`, `/garanties`, `/confidentialite`, `/cookies`, `/preferences` | toutes les routes répondent en HTTP 200 hors session, maillage du pied de page sans lien mort | ENF-14, LCEN | automatisé (`pages_pied_de_page_test`, `contract_http`, `wasm-e2e`) |
| F | Catégorie non vide protégée en 2 étapes | catégorie portant des produits | `GET /admin/categories/{id}/suppression/confirmation` puis `POST` | refus humain en français avec lien de réaffectation vers `/admin/produits` ; suppression acceptée une fois la catégorie vidée | RB-14 | automatisé (`actions_destructrices_test`, `wasm-e2e`, `T-14`) |
| F-26 | Ajustement de stock et refus de négatif | `ENCH-006` stock 30 | `DELTA +15` (motif réception), `SET 0` (motif inventaire), puis `DELTA -99999` | `30 -> 45 -> 0` ; le passage en négatif est refusé avec message humain en français (sans code `RB03_...`) et le stock reste à `0` | RB-03, RB-17 | automatisé (`stocks_defaut_test`, `wasm-e2e`, `T-19`) |
| F | Alertes de stock (`RUPTURE` / `TRES_BAS`) | `POWER-010` stock 0 ; `MICRO-007` stock 2, seuil 2 | `GET /admin/stocks?etat=alerte` | remontée exacte des articles en `RUPTURE` et `TRES_BAS`, alignée entre dépôt PHP et vue SQL `v_etat_stock` | ENF-13, RB-03 | automatisé (`catalogue_stock_test`, `T-26`, `T-27`) |
| F-28 | Recherche et filtre de période des commandes (admin) | jeu de démo | `GET /admin/commandes?statut=EXPEDIEE&du=2026-01-01&au=2026-12-31` puis `du > au` | commandes et cumul filtrés selon les bornes UTC du fuseau actif ; `du > au` demande une correction sans erreur 500 | RB-10, RB-15 | automatisé (`commandes_tableau_test`, `heure_test`, `wasm-e2e`) |
| F | Transitions de statut autorisées et interdites | commande `EXPEDIEE` | `POST /admin/commandes/{id}/statut` avec `statut=BROUILLON` | refus humain en français (aucun code `RB11_...`), statut et historique inchangés ; l'interface ne propose que `LIVREE` ou `ANNULEE` | RB-11, RB-09 | automatisé (`TriggersTest`, `wasm-e2e`, `T-12`, `T-13`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F-30 | Piste d'audit complète | commande ayant évolué | `GET /admin/commandes/{id}` | chronologie complète des transitions avec statut avant/après, auteur, rôle, commentaire et date locale | RB-11 | automatisé (`wasm-e2e`, `T-22`) |
| F | Indicateurs du tableau de bord | jeu de démo | `GET /admin` | chiffre d'affaires par statut, panier moyen, top 5 produits et indicateurs du jour local (`jour_local`) cohérents | - | automatisé (`heure_test`, `wasm-e2e`) |
| F-32 | Séparation stricte des rôles (`CLIENT`, `GESTIONNAIRE`, `SUPER`) | `alice` et un admin `GESTIONNAIRE` | `GET /admin` comme `alice` ; `GET` et `POST /admin/equipe` comme `GESTIONNAIRE` | `alice` redirigée vers `/admin/connexion` ; `GESTIONNAIRE` reçoit un **HTTP 403** sur `/admin/equipe` ; aucune route publique ne crée d'admin | RB-13, SEC-10 | automatisé (`features_test`, `wasm-e2e`) |
| F | Frais de livraison affichés avant validation puis figés | panier < 80 EUR puis >= 80 EUR | ouvrir `/panier` et `/commande/valider`, valider, relire `frais_port` et `montant_total` | 4,90 EUR affichés avant validation sous 80 EUR (0,00 EUR « offerte » dès 80 EUR), figés à l'identique en base, absents des champs modifiables | ENF-14, RB-15 RB-20 | automatisé (`valider_recap_test`, `wasm-e2e`, `T-28`) |
| F-34 | Cumul et réinitialisation des filtres catalogue | filtres actifs sur `/catalogue` | combiner catégorie + recherche + prix + stock, puis cliquer « Réinitialiser » | conservation intégrale des filtres au tri/pagination, retour propre au catalogue complet au clic sur réinitialiser | EF-VIS-03/05 | automatisé (`catalogue_filtres_test`, `ui-e2e-catalogue`) |
| F | Double implémentation des visuels produits (décoratif / informatif) | catalogue et fiche produit | inspecter `<img>` sur `/` et `/catalogue` puis sur `/produit/{slug}` (cartes similaires incluses) | cartes listes/similaires en mode **décoratif** (`alt=""`) ; fiche produit en mode **informatif** (`alt="Visuel indicatif : ..."` FR / `"Illustrative image: ..."` EN) ; zéro requête distante | Accessibilité, DA | automatisé (`cartes_accessibilite_test`, `fiche_produit_test`, `preferences_test`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F-36 | Cohérence loyale de `/contact`, `/retractation`, `/cgv` et `/a-propos` | - | soumettre `/contact` (succès puis échec d'écriture sur copie jetable) et lire `/retractation` | accusé honnête de journalisation locale sans promesse d'e-mail ; distinction claire entre annulation technique avant expédition et droit légal de rétractation | Information loyale | automatisé (`contact_coherence_test`, `cgv_retractation_test`, `apropos_test`, `ui-e2e-contact`, `ui-e2e-retractation`) |
| F | Zéro code technique brut à l'écran (FR et EN) | erreurs métier provoquées | déclencher stock insuffisant, doublon, transition interdite, jeton CSRF invalide en FR et EN | phrases humaines exclusivement ; aucun identifiant `RB03_`, `SQLSTATE`, `STOC _INSUFFISANT` ou trace PHP affiché | SEC-12, Ergonomie | automatisé (`codes_techniques_test`, `ui-e2e-codes`, `preferences_test`) |
| F-38 | Confirmations en 2 étapes sans JavaScript sur toute action définitive | client ou admin, JS coupé | ouvrir en GET chaque page `*/confirmation` (ou 1er POST d'annulation admin), la recharger, cliquer « Non », puis confirmer en POST | les GET et le bouton « Non » n'ont **aucun effet de bord** ; seul le POST explicite final exécute l'action | SEC-06, Ergonomie | automatisé (`actions_destructrices_test`, `ui-e2e-annulation`, `responsive_navigateur`) |
| F | Tenue responsive 320/375 px de `/compte` et adresse pré-remplie | client connecté, viewport 320 & 375 px (CI Chromium) | saisir rue, code postal et ville sur `/compte`, ouvrir `/commande valider` | aucun débordement horizontal ; adresse structurée pré-remplie à la validation | EF-CLI-01, Responsive | automatisé (`adresse_livraison_test`, `responsive_navigateur`) |
| F-40 | Tenue responsive 320/375 px de `/commande/valider` | panier multi-lignes, 320 & 375 px (CI Chromium) | ouvrir `/commande/valider` et inspecter le récapitulatif et le bloc totaux | cartes mobiles `data-label` propres, totaux groupés, bouton d'action complet et liens précontractuels lisibles | EF-CLI-07, Responsive | automatisé (`valider_recap_test`, `ui-e2e-valider`, `responsive_navigateur`) |
| F | Tenue responsive 320/375 px de `/mes-commandes` et du détail annulé | commandes active annulée, 320 & 375 px (CI Chromium) | ouvrir `/mes-commandes` et `/mes-commandes/{id}` | cartes mobiles étiquetées sans défilement horizontal ; lignes et `Total avant annulation` lisibles | EF-CLI-08/09, Responsive | automatisé (`mes_commandes_tableau_test`, `ui-e2e-mes-commandes`, `responsive_navigateur`) |
| F-42 | Inscription : affichage groupé des erreurs et conservation des saisies | session visiteur | poster `/inscription` avec nom vide + e-mail invalide + mot de passe court + CGV non cochées | toutes les erreurs sont listées dès le premier envoi ; champs non sensibles conservés, mots de passe vidés | EF-VIS-06, Ergonomie | automatisé (`inscription_erreurs_test`, `ui-e2e-inscription`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F | Doublon de catégorie refusé sans écrasement silencieux | catégorie `Audio` existante | créer une catégorie `audio` / `Audio` avec une autre description | refus « Ce nom de catégorie existe déjà. » ; description et produits de la catégorie `Audio` d'origine intacts | EF-ADM-03, RB-07 | automatisé (`categorie_doublon_test`, `ui-e2e-categories`) |
| F-44 | Mode d'ajustement de stock par défaut non destructif (`DELTA`) | session admin sur `/admin/stocks` | saisir `+5` et un motif sans toucher au menu déroulant du mode | l'option pré-sélectionnée est « Ajouter / retirer » (`DELTA`) et ajoute 5 au lieu d'écraser le stock à 5 | EF-ADM-04, Ergonomie | automatisé (`stocks_defaut_test`, `ui-e2e-stocks`) |
| F | Alignement typographique des montants et quantités (`tabular-nums`) | tableaux panier, commandes, admin | inspecter l'alignement des colonnes numériques et monétaires | alignement à droite cohérent entre `th` et `td`, chiffres tabulaires lisibles | DA, Ergonomie | automatisé (`alignement_colonnes_test`, `ui-e2e-alignement`) |
| F-45 | Tableaux et formulaires d'administration en cartes mobiles `data-label` | session admin, 320 & 375 px (Cl Chromium) | parcourir `/admin`, `/admin/produits`, `/admin/categories`, `/admin/stocks`, `/admin/commandes` `/admin/equipe` avec valeurs longues | repli en cartes mobiles étiquetées (`data-label` identique au `th`), valeurs longues repliées sans sortir du cadre, `scrollWidth <= innerWidth` | Responsive, USWDS / WCAG 1.4.10 | automatisé (`categories_tableau_test`, `commandes_tableau_test`, `formulaires_admin_test`, `responsive_navigateur`) |
| F | Tenue 320/375 px de `/panier`, unicité des totaux et bouton principal | panier garni, 320 & 375 px (Cl Chromium) | ouvrir `/panier` et contrôler lignes, pied de tableau et CTA | cartes `data-label` propres, totaux affichés une seule fois dans `tfoot`, bouton « Valider ma commande » m en évidence | EF-CLI-03...06, Responsive | automatisé (`panier_tableau_test`, `panier_cta_test`, `ui-e2e-panier-tableau`, `responsive_navigateur`) |
| F-46 | Annulation administrateur avant vs après expédition et garde SQL | commandes `PAYEE` et `EXPEDIEE` | annuler en 2 étapes côté admin les deux commandes ; tester `sp_update_order_status(..., 'ANNULEE')` direct en SQL | avant expédition : stock restitué 1 fois ; sur `EXPEDIEE` : avertissement dédié, montants soldés mais **stock non restitué** ; appel SQL direct bloqué par `ANNULATION_VIA_PARCOURS_DEDIE` | EF-ADM-07, RB-11, RB-18 | automatisé (`actions_destructrices_test`, `JsonStoreTest`, `sql_integration`, `wasm-e2e` T15, `responsive_navigateur`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| F | Mentions légales étudiantes (Point 20 - LCEN art. 6, III, 2) | - | ouvrir `/mentions-legales`, `/mentions` et `/cgu` en FR puis en EN | co-éditeurs étudiants **Johan Polsinelli** et **Chahd Gouiaa** (SAE S3.02, BUT Info IUT Nice Côte d'Azur), e-mails universitaires sans domicile/téléphone personnel (art. 6, III, 2 LCEN), hébergeur IUT `linserv-info-01.campus.unice.fr` (28 av. Valrose, `+33 (0)4 89 15 00 00`) | LCEN art. 6, III, 2 | automatisé (`mentions_legales_test`, `ui-e2e-mentions`, `preferences_test`, `responsive_navigateur`, `wasm-e2e` T15) |
| F-50 | Préférences personnelles `/preferences` (stockage local seul et replis) | visiteur non connecté | choisir langue et fuseau sur `/preferences`, réinitialiser, tester `localStorage` bloqué et JS coupé | écriture dans `localStorage['minishop.preferences.v1']` uniquement, zéro cookie de suivi ; repli `fr`->`Europe/Paris`, `en`->`America/New_York` ; mention sur la révocation navigateur à la réinitialisation ; repli sans JS propre | RGPD / CNIL traceurs, Accessibilité | automatisé (`preferences_test`, `heure_test`, `wasm-e2e` T15, `responsive_navigateur`) + test navigateur réel `[!]` |
| F | Géolocalisation volontaire locale sans tiers (`tz-lookup` CC0) | visiteur sur `/preferences` | cliquer « Utiliser ma position » (refus puis accord) en observant le réseau et `localStorage` | zéro requête réseau vers un tiers, zéro coordonnée GPS transmise ou stockée ; affichage du fuseau IANA estimé avec avertissement d'approximation et correction manuelle possible | CNIL localisation, Vie privée | automatisé (`preferences_test`, `information_juridique_test`) + test permission navigateur réel `[!]` |
| F-52 | Traduction complète FR <-> EN (`traduire_tout`) et réversibilité | 48 vues du site + panier AJAX | basculer `Français -> English -> Français` sur front, légal, panier AJAX, erreurs métier, client et admin | `<html lang>` et `<title>` synchronisés, 100 % des textes d'interface, messages flash/API et `data-label` traduits, saisies formulaires préservées, aucun débordement en CI Chromium | WCAG 3.1.1, Ergonomie bilingue | automatisé (`preferences_test` sur 48 vues + 44 erreurs, `responsive_navigateur`) + test navigateur réel `[!]` |

| | | | | | | |
|---|---|---|---|---|---|---|
| F | Stockage UTC de bout en bout et affichage/filtrage en fuseau local | session SQL décalée + fuseaux hiver/été | créer des enregistrements, inspecter `<time datetime="...Z">`, filtrer `du`/`au` sur `/admin/commande` et `jour_local` sur `/admin` | sessions PDO forcées à `+00:00`, stockage UTC invariant, conversion exacte (y compris jours DST de 23 h / 25 h) à l'affichage et dans les bornes UTC des filtres | Intégrité temporelle | automatisé (`ConservationEtFuseauTest`, `heure_test`, `sql_integration`, `preferences_test`, `wasm-e2e` T15) |
| F-50 | Conservation `24 mois` et outil CLI de purge des comptes inactifs | copie jetable du magasin | lancer `php scripts/purger_comptes.php` (simulation) puis `--executer` | simulation sans écriture ; `--executer` ne supprime que les comptes inactifs >= 24 mois + 2 j **sans commande** et préserve ceux ayant commandé ou à date invalide/future | RGPD art. 5.1.e, CNIL référentiel | automatisé (`ConservationEtFuseauTest`, `retention_comptes_test`, `sql_integration`, `test_retention_cli.py`) |
| F | Rotation CLI (contacts `12 mois`, journaux `6 mois`, sauvegardes `30 j`) et archives chiffrées | copie jetable + dossier `.minishop-sauvegardes` | lancer `scripts/nettoyage_donnees.php` et `scripts/archive_restreinte.php` en simulation puis exécution | rotation atomique sous verrou (au moins 2 sauvegardes récentes gardées, refus hors dossier dédié) ; archive chiffrée `sodium` en permissions `0700` sans altérer la source | RGPD art. 5.1.e / 32 | automatisé (`ConservationEtFuseauTest`, `nettoyage_fichiers_test`, `test_nettoyage_cli.py`, `test_archive_restreinte.py`) |
| F-500 | Minimisation des journaux d'audit et transparence `/confidentialite` & `/500` | copie jetable | créer/modifier client et admin, inspecter le journal JSONL, lire `/confidentialite` et `/500` | aucun nom, e-mail, adresse ni `mot_de_passe_hash` dans les nouvelles entrées `client`/`administrateur` ; page `/500` sans fausse garantie « aucune donnée modifiée » | RGPD art. 5.1.c / 13, SEC-12 | automatisé (`JournalEtTableTest`, `information_juridique_test`, `divers_test`) |

## 3.1 Trois cas détaillés au format complet

| Champ | F-16 - Validation complète d'une commande | F-18 - Stock insuffisant sur la 2e ligne | F-21 - Annulation client en 2 étapes et restitution |
|---|---|---|---|
| Préconditions | seed chargé ; C1 (compte fictif de test) connecté, adresse au profil ; panier = {`CASQ-005` × 2} | panier = {`CASQ-005` × 1, `MICRO-007` × 3} avec `MICRO-007` en stock 2 | commande « En préparation » contenant `SAC-008` × 2 ; stock `SAC-008` = 22 |
| Données en entrée | `id_client` (session), adresse fictive du profil « Adresse de test, 00000 Ville » (pré-remplie), jeton CSRF | idem, lignes du panier en session | `id_commande`, confirmation explicite sur la page dédiée |

| | | | |
|---|---|---|---|
| Étapes | 1. `/panier` -> bouton « Valider ma commande » ; 2. page Valider : récapitulatif tenu en page (F-40) ; 3. bouton « Confirmer et payer : 309,60 EUR (simulé) » | 1. idem ; 2. confirmer | 1. `/mes-commandes/{id}` ; 2. « Annuler la commande » -> **page GET de confirmation** (la recharger ne fait rien, F-38) ; 3. confirmer en POST |
| Résultats attendus | HTTP 200 ; commande `CMDAAAANNNNNN` créée ; montant 309,60 EUR (port offert dès 80 EUR) ; 1 ligne 2 × 154,80 EUR ; stock décrémenté de 2 ; historique initial présent ; panier vidé | message « Stock insuffisant pour cette quantité. » (ou traduction EN si langue anglaise active) ; aucune commande créée ; stock `CASQ-005` inchangé (rollback complet) ; panier conservé | statut « Annulée » ; **lignes conservées en historique** ; stock 22 -> 24 **exactement** (un seul crédit) ; montant et port soldés à `0,00 EUR` avec « Total de la commande avant annulation » conservé ; plus aucune action possible |
| Preuves | captures + contrôles affichés (détail commande, ligne, stock, historique) ; côté base : `SELECT` sur `commande`, `ligne_commande`, `produit`, `order_status_history` | pages avant/après + compteurs (commandes, stocks) inchangés | détail de la commande annulée (lignes et montants soldés) + historique + stock relu |
| Règles vérifiées | RB-04, RB-06, RB-11, RB-15, RB-18 | RB-04, RB-18, ENF-16 | RB-09, RB-11, RB-18 |
| Statut | automatisé (`wasm-e2e`, `ui-e2e-valider`, `ui-e2e-mes-commandes`) | automatisé (`features_test`, `wasm-e2e`, `T-29`) | automatisé (`ui-e2e-annulation`, `ui-e2e-annulation-historique`, `annulation_historique_test`, `T-21`) |

## 4. Tests de sécurité (offensifs)

| ID | Cas d'attaque | Mode opératoire | Résultat attendu | Exigence |
|---|---|---|---|---|
| S-01 | Injection SQL dans la recherche | Les tentatives SQL destructives ou d'extraction (`UNION` sur les tables de comptes, `DROP`, etc.) sont `BLOQUÉ` sur la production ; sur LineServ, utiliser seulement une recherche littérale non destructive via l'interface. | Réponse normale/validation sans erreur technique ni divulgation ; les payloads agressifs et vérifications par SQL direct restent aux tests automatisés isolés/CI. | SEC-01, SEC-02 |
| S-02 | Script stocké puis affiché (XSS) | Avec un compte admin de test, créer un produit de test nommé `<script>console.log('test')</script>` puis ouvrir sa fiche et la liste admin avec un compte de test (FR et EN) | Texte affiché littéralement (`<script>`) ; aucune exécution ni requête externe ; CSP stricte (`script-src 'self'`, aucun inline). Supprimer le produit uniquement via l'interface avant la restauration finale si nécessaire. | SEC-03 |
| S-03 | IDOR sur les commandes | Avec deux comptes synthétiques C1/C2, ouvrir uniquement une commande de test de C2 depuis la session de C1 via l'interface/HTTP ; ne pas énumérer des identifiants réels ni appeler une procédure SQL | 404 sur la commande de test d'autrui ; aucune donnée divulguée. La vérification SQL de `sp_confirm_order` (`T-18`) reste en CI. | SEC-08 |

| | | | | |
|---|---|---|---|---|
| S-0 | Falsification du prix ou du port | Sur un panier/client de test, modifier les champs de prix/port dans une requête HTTP contrôlée ; ne pas effectuer d'`UPDATE` SQL | Si une commande de test est créée, ses montants restent ceux calculés côté serveur ; la garde SQL contre `UPDATE` direct (`T-11`, `T-28`) est vérifiée uniquement en CI. | SEC-10, RB-06 |
| S-05 | Vol / fixation de session | capturer l'identifiant de session avant login et le rejouer après authentification | identifiant pré-authentification invalidé (`session_regenerate_id(true)`) ; cookie `HttpOnly` et `SameSite=Lax` | SEC-05 |
| S-0 | CSRF sur toute action mutative (HTML et JSON) | poster formulaires et `/api/panier/*` sans jeton ou avec jeton périmé | refus **403** avec message humain explicite, aucune écriture ; les pages GET de confirmation (F-38) restent sans effet de bord | SEC-06 |
| S-07 | Énumération et exposition de fichiers privés | tenter `/.git/config`, `/.env`, `/sql/01_minishop_schema.sql`, `/var/log/application.log`, `/app/Config/env.php` | 403/404 sur tous ces chemins ; en-têtes `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: same-origin` et CSP présents | SEC-11, SEC-12 |
| S-0 | Fuite d'information dans les messages et journaux | Provoquer uniquement une erreur métier avec les données de test ; ne pas couper la base ni provoquer volontairement une panne de production | Page générique sans SQL, chemin interne ni code `RB*` ; aucune donnée sensible dans les preuves/journaux. La coupure DB est `BLOQUÉ` sur LineServ. | SEC-12, SEC-13 |
| S-09 | Force brute sur l'authentification | Aucune rafale ni script de force brute sur la production LineServ ; seuls quelques échecs manuels à faible cadence sur un compte de test sont permis selon `TC05-09`, sinon `BLOQUÉ` | message neutre constant ; **limite connue documentée** : pas de limiteur de débit applicatif intégré dans la maquette scolaire | SEC-04, SEC-06 |
| S-1 | Élévation de privilège par formulaire | ajouter `role=SUPER` ou `est_admin=1` dans `POST /inscription` ou `POST /compte` | champs ignorés ; compte strictement client ; table `administrateur` jamais touchée | SEC-10, RB-13 |

Les contrôles manuels navigateur/HTTP de `TCX-01`...`TCX-05` ne portent que sur des comptes et données de test synthétiques de LineServ, avec autorisation, sans SQL direct, extraction de comptes, rafale ni panne. Les scénarios exigeant une instance isolée, une mutation hors des données de test ou une attaque à charge élevée sont `BLOQUÉ` pour la campagne de production. Les tests automatisés sont couverts par `scripts/wasm-e2e.mjs` (T6, T12, T13), `tests/phpunit/SecurityContractTest.php` et `tests/php/contract_http.php`. Les **10 contrôles statiques** (+ auto-test sur fixtures fautives) sont bloquants en CI : `bash tests/security/controles.sh` ; aucun test automatisé ni SQL direct ne doit viser la base de production.

## 5. Tests de performance, de concurrence, d'installation et de restauration

| ID | Scénario | Commande | Critère et état |
|---|---|---|---|

| | | | |
|---|---|---|---|
| P-01 | Catalogue filtré, 200 produits | `bash tests/perf/mesurer.sh '/catalogue?cat=1&prix_max=500'` | p95 < 500 ms, <= 5 requêtes (`ENF-01`) - mesure LineServ uniquement avec autorisation explicite, faible cadence et fenêtre pré-démo ; sinon `BLOQUÉ` `[!]` |
| P-02 | Recherche « casque » | `bash tests/perf/mesurer.sh '/recherche?q=casque'` | p95 < 500 ms ; `EXPLAIN` utilisant `idx_produit_visible` ou `FULLTEXT` (`ENF-02`) - aucun `EXPLAIN` ou accès SQL direct sur la base de production ; mesure HTTP LineServ seulement avec autorisation explicite et faible cadence, sinon `BLOQUÉ` `[!]` |
| P-03 | Validation de commande | `bash tests/perf/mesurer.sh '/commande/valider'` (POST) | p95 < 900 ms avec verrous - uniquement sur panier/compte synthétique, avec autorisation explicite et une exécution contrôlée ; sinon `BLOQUÉ` `[!]` |
| P-04 | Performances côté base sur jeu de volumétrie | `sudo bash scripts/capture_perf.sh` (jeu local dédié, hors LineServ) | Contrôle automatisé/local seulement ; ne pas créer de base secondaire ni lancer `EXPLAIN`/volumétrie sur la production LineServ dans la recette manuelle |
| C-01 | Tentative de survente concurrente | `bash tests/charge/reserver.sh 20 12` (et `php tests/php/json_concurrency_stress.php`) | Le stress JSON est exécuté en CI. Ne pas lancer 20 requêtes concurrentes contre LineServ dans la recette ordinaire ; tir HTTP SQL uniquement après accord écrit de l'hébergeur, sur stock synthétique dédié, sinon `BLOQUÉ` `[!]` |
| C-02 | Rejeu du POST de commande / double annulation | rejouer une fois le même `POST /commande/valider` ou `POST .../annulation` pour une commande de test LineServ | au plus une commande / une seule restitution de stock (`TC07-08`, `TC09-02`, `TC09-09`) ; arrêter après le contrôle et restaurer la base avant la démo |
| I-01 | Durée d'installation sur poste vierge | suivi du `README.md` seul puis `./scripts/run_sql_tests.sh` | **29/29** tests SQL conformes ; chronométrage humain <= 15 min **à relever `[!]`** |
| B-01 | Sauvegarde / restauration complète | sauvegarde SQL complète avec routines/triggers, puis restauration selon une procédure approuvée | Vérifier la procédure avant la campagne ; la restauration de la sauvegarde pré-campagne dans la même base LineServ est le retour obligatoire à l'état de démo. Ne pas exécuter une commande de restauration non validée ni restaurer sur un nom de base supposé `[!]` |

## 6. Tests unitaires PHPUnit (9 classes, 50 tests)

Commande : `vendor/bin/phpunit` (JUnit en CI) ou `php tests/phpunit/run-local.php` (`node scripts/wasm_run.mjs tests/phpunit/run-local.php` hors ligne).

| Classe de test | Cas testés | Attentes vérifiées |
|---|---|---|
| `TextTest` | normalisation, slugs, casse et accents (avec et sans `intl`), échappement HTML `e()` | slugs déterministes, recherche insensible aux accents/casse, aucun HTML actif |
| `FilterTest` | `SearchQuery` : tri inconnu, `par_page = 500`, `prix_min > prix_max`, bornes de page | repli sur liste blanche, plafond 60, filtres invalides neutralisés sans exception |
| `PrixTest` | calculs HT/TVA/TTC (20 %, 5,5 %), sous-totaux, franchise et frais de port | arrondis exacts au centime sans dérive flottante |
| `TriggersTest` | matrice complète des 36 couples `RB-11`, immutabilité des lignes, règles de stock et montants | conformité exacte aux 9 transitions autorisées et aux gardes métier |
| `JsonStoreTest` | transactions, validation commande, annulation client (restitution stock + conservation lignes), refus d'usurpation/double annulation, annulation admin `EXPEDIEE` sans retour de stock | atomicité complète, stock exact, `ANNULATION_TROP_TARDIVE` côté client après expédition |
| `SecurityContractTest` | hachage bcrypt 60 car., jetons CSRF, garde des routes `/admin*`, absence de secrets versionnés | rejet de tout hash invalide ou requête mutative non signée |
| `AlternativeImageTest` | double implémentation `image_produit()` : mode décoratif (`alt=""`) vs mode informatif (`alt="Visuel indicatif : ..."`), échappement HTML, rejet d'une description informative vide ou d'une URL distante | conformité stricte au choix explicite de chaque vue (carte liste décorative vs fiche produit informative) |
| `JournalEtTableTest` | écriture/lecture des journaux et minimisation des données dans `Journal.php` | aucune donnée nominative ni `mot_de_passe_hash` dans les nouvelles traces `client`/`administrateur` |
| `ConservationEtFuseauTest` | `Heure` (UTC, `Europe/Paris`, DST 23 h / 25 h, `borneTransmise`), `RetentionComptes` (24 mois, simulation, exclusion commandes/dates futures, purge), `NettoyageJournaux` & `NettoyageSauvegardes` | stockage UTC strict, conversions locales exactes et purges conservatrices sûres |

## 7. Registre des anomalies (issues réelles résolues et verrouillées)

| # | Constat | Gravit | Cause racine | Correction | Verrou de non-régressi |
|---|---|---|---|---|---|
| A-01 | un `UPDATE` du prix d'une ligne était « réparé » au lieu d'être rejeté | majeure | ordre de création des triggers | ordre corrigé dans `sql/03_minishop_triggers.sql` | `T-11` |
| A- | doublons dans `order_status_history` | mineu | écriture en procédure **et** en trigger | écriture confiée au seul trigger `trg_history_statut` | `T-22` |

| | | | | | |
|---|---|---|---|---|---|
| A-03 | stock restitué deux fois ou lignes perdues à l'annulation | **bloquante** | double décrémentation/purge des lignes | parcours dédié `sp_cancel_order` / `cancelOrder`, conservation des lignes + `montant_avant_annulation`, garde `ANNULATION_VIA_PARCOURS_DEDIE` | `T-21`, `F-21`, `F-48`, `JsonStoreTest` |
| A- | `SELECT ... INTO NEW.prix_unitaire` refusé en trigger | bloquante | syntaxe non permise par MySQL/MariaDB | variable locale puis `SET NEW.prix_unitaire = v` | `scripts/load_db.php` |
| A-05 | erreur MySQL 1442 lors d'une purge de fixture | bloquante | sous-requête lisant `produit` sous trigger | table temporaire dans `tests/sql/fixture.sql` | harnais SQL |
| A- | `LIMIT :lim` rejeté en requête préparée de procédure | bloquante | marqueurs nommés non supportés en `PREPARE` | marqueurs positionnels `?` | `T-25` |
| A-07 | `v_catalogue` cassée par un test redéfinissant `v_etat_stock` + conflit de collation MariaDB 11.4+ (`ERROR 1267`) | bloquante | vue de prod écrasée en test et collation de session implicite | `id_produit` exposé dans `v_etat_stock` ; `SET NAMES utf8mb4 COLLATE utf8mb4_unicode_ci` partout | `T-26`, `T-27`, `unit_tests` |
| A- | agrégation par statut de `sp_revenue_report` en `ALL` | mineure | `GROUP BY` + `AVG(montant_total)` | documenté et accepté à la volumétrie cible (1 000 commandes/an) | `P-06` |
| A-09 | `CURRENT_TIMESTAMP` dépendait du fuseau du serveur SQL au lieu d'UTC | majeure | session PDO non forcée à `+00:00` | `SET time_zone = '+00:00'` imposé et vérifié sur `DbConnexion` / `SqlStore` | `ConservationEtFuseauTest`, `sql_integration` |
| A- | annulation admin d'une commande `EXPEDIEE` recréditait ou ignorait le stock sans parcours dédié | majeure | passage direct par changement de statut simple | confirmation en 2 étapes, `cancelOrder` avec retour stock avant expédition et **sans** retour automatique sur `EXPEDIEE` | `F-48`, `TC14-06`, `TC14-11`, `TC14-12` |

## 8. État de validation et procès-verbal de recette

Vérification automatisée complète exécutée le **23/10/2026** sur la branche de livraison : `node scripts/run-all-tests.mjs` 100 % vert et pipeline GitHub Actions **15/15 jobs verts** (PHP 8.2 et 8.5, MySQL 8.0, MariaDB 11.8, concurrence JSON, JSDOM 48 vues FR<->EN, Playwright Chromium 320/375/1440 px FR+EN avec et sans JS).

| Zone | Vérifications du plan | Automatisées et vertes en CI | À jouer / compléter manuellement `[!]` | Bloquantes | Majeures | Preuve principale |
|---|---|---|---|---|---|---|
| Base de données (contraintes, procédures, triggers, vues, UTC, migration) | 29 (`T-01`...`T-29`) | **29** | 0 (tests SQL automatisés uniquement sur `minishop_test` en CI ; aucun rejeu manuel sur la base de production) | 0 | 0 | jobs CI MySQL 8.0 & MariaDB 11.8 (`sql_integration.php` + étape 6 + `migration_mariadb_test.php`) |

| | | | | | | |
|---|---|---|---|---|---|---|
| Installation / sauvegarde | 2 (`F-00`/`I-01`, `B-01`) | **1** (chargement auto `db_init`) | **2** (chronométrag humain `I-01` <= 15 min et restauration `B-01`) | 0 | 0 | jobs CI SQL ; protocole manuel §5 |
| Parcours fonctionnels front, client, admin (`F-01`...`F-48`) | 48 | **48** | **0** (responsive multi-largeurs délégué à la CI Chromium, hors suites manuelles) | 0 | 0 | 42 suites PHP + `wasm-e2e` (338 contrôles) + 23 `ui-e2e-*` + Chromium CI |
| Mentions LCEN, `/preferences`, FR<->EN, UTC, conservation & RGPD maquette (`F-49`...`F-56`) | 8 | **8** | **3** contrôles humains navigateur réel (`F-50`, `F-51`, `F-52`) | 0 | 0 | `preferences_test.mjs`, `ConservationEtFuseauTest`, `mentions_legales_test.php`, suites Python CLI |
| Sécurité (cas offensifs + contrôles statiques) | 20 (`S-01`...`S-10` + 10 contrôles) | **20** | rejeu exploratoire sur hébergement cible (`TCX-01`...`TCX-10`) | 0 | 0 | `tests/security/controles.sh` (10/10) + `wasm-e2e` T6/T12/T13 + PHPUnit |
| Performance et charge | 6 (`P-01`...`P-03`, `P-06`, `C-01`, `C-02`) | **2** (`C-01` JSON + `C-02` E2E) | **5** mesures HTTP/SQL sur machir de recette (`P-01`...`P-03`, `P-06`, `C-01` SQL) | 0 | 0 | `json_concurrency_stress.php`, `wasm-e2e` ; scripts `tests/perf/*` prêts |
| **Sous-total du présent document** | **113 vérifications** (29 + 2 + 48 + 8 + 20 + 6) | **108 automatisées en CI** | **10 compléments humains `[!]`** | **0** | **0** | pipeline CI 15/15 vert |
| **Campagne manuel complète par UC (`docs/13-*`)** | **200 entrées** (164 scénarios `TC*` + 36 couples `TC14-09/*`) | structure vérifiée (`46/46` via `verifier_fiches_uc.py`) | **200 `NON JOUÉ`** dérouler par l'équipe | - | - | [`docs/13-suivi-recette-uc.csv`](13-suivi-recette-uc.csv) |

Signature de l'équipe, date : ..... Validation du maître d'ouvrage pédagogique (soutenance), date : .....

## 9. Matrice de traçabilité exigence -> modèle -> base -> application -> tests

| Exigence / volet | Élément de modèle | Mécanisme de base / stockage | Point d'application PH / JS / IHM | Tests automatisés & manuels |
|---|---|---|---|---|
| EF-VIS-01/03/05 | `Categorie`, `Produit` | `sp_search_products`, `idx_produit_visible`, `v_catalogue` | `CatalogueController`, visuels décoratifs en liste (`alt=""`) | F-01, F-03, F-04, F-34, F-35, T-25, UC-01 |
| EF-VIS-02 | `Produit` | `sp_search_products` (marqueurs `?`) | recherche + liste blanche de tri | F-02, S-01, T-25, UC-02 |
| EF-VIS-04 | `Produit` | `trg_produit_ttc` | fiche produit + visuel informatif indicatif | F-05, F-35, UC-03 |
| EF-VIS-06/07 | `Client` | `sp_create_account`, `sp_get_credentials` | `AuthController`, `Auth`, `Hasher` | F-06...F-08, F-42, T-04, T-05, UC-04, UC-05 |
| EF-CLI-01/02 | `Client` | `sp_update_client` | `CompteController` (adresse structurée) | F-10, F-11, F-39, UC-05 |

| | | | | |
|---|---|---|---|---|
| EF-CLI-03...06 | `PanierSession` | `sp_search_products` (plafond de stock) | `PanierController` + `ApiController` + `public/js/panier.js` (`script-src 'self'`, repli complet sans JS) | F-12...F-15, F-47, UC-06 |
| EF-CLI-07 | `Commande`, `LigneCommande` | `sp_create_order_from_basket`, `sp_add_order_line`, triggers A1/A2/B2/D1/D4 | `CommandeController` + `CommandeRepository` | F-16...F-18, F-33, F-40, T-06...T-11, T-16, T-28, T-29, UC-07 |
| EF-CLI-08/09 | `Commande` | `trg_history_statut`, `v_commandes_client` | `CommandeController` (filtre `id_client`, 404 sur autrui) | F-19, F-20, F-41, S-03, T-18, UC-08 |
| EF-CLI-10 | `Commande` | `sp_cancel_order` + conservation lignes + `montant_avant_annulation` | confirmation GET sans effet + POST d'annulation | F-21, F-38, T-21, UC-09 |
| EF-ADM-01/02 | `Produit` | `sp_save_product`, `sp_delete_product`, triggers B3-B6 | `ProduitAdminController` (confirmation suppression 2 étapes) | F-22, F-23, F-38, T-15, T-20, UC-10 |
| EF-ADM-03 | `Categorie` | `sp_save_category`, `sp_delete_category`, `uk_categorie_nom/slug` | `CategorieAdminController` (refus doublon, confirmation 2 étapes) | F-25, F-43, T-14, UC-11 |
| EF-ADM-04/05 | `Produit.stock` | `sp_adjust_stock`, `v_etat_stock` | `StockAdminController` (mode par défaut `DELTA`) | F-26, F-27, F-44, T-19, T-26, T-27, UC-12 |
| EF-ADM-06/08/09 | `Commande` | `sp_revenue_report`, `v_commandes_client`, bornes UTC | `DashboardController`, `CommandeAdminController`, cartes `data-label` | F-28, F-30, F-31, F-46, F-53, UC-13 |
| EF-ADM-07 | `Commande.statut` | `sp_update_order_status` (garde `ANNULATION_VIA_ARCOURS_DEDIE`), `sp_cancel_order` | confirmation 2 étapes d'annulation admin (avec/sans retour de stock selon `EXPEDIEE`) | F-29, F-48, T-12, T-13, UC-14 |
| Préférences FR/EN & fuseau | `Heure` | sessions SQL en UTC `+00:00`, `localStorage` navigateur seul | `/preferences`, `preferences.js`, `tz-lookup.js` (CC0 local), `i18n-en.js` | F-50, F-51, F-52, F-53, TCX-19...TCX-23 |
| Mentions LCEN conservation | `RetentionComptes`, `Nettoyage*`, `Journal` | `conservation_compte = 24` mois, verrous atomiques, archives `sodium` | `/mentions-legales` (Point 20), `/confidentialite`, `scripts/{purger_comptes,nettoyage_donnees,archive_estreinte}.php` | F-24, F-36, F-49, F-54...F-56, TCX-17, TCX-18, TCX-24 |
| SEC-01...SEC-13 | - | `CHECK` / `FK` / triggers / moindre privilège | PDO préparé, `e()`, `Auth`, CSRF, CSP stricte, journaux minimisés | S-01...S-10 + 10 contrôles CI + TCX-01...TCX-05 |
| ENF-01/02/15/1 | - | index, `FULLTEXT`, transactions, `mysqldump --routines --triggers` | scripts `tests/perf/*`, `rollBack()` | P-01...P-06, B-01, F-18, T-09, T-29, TCX-14, TCX-15 |

## 10. Conclusion

- la **base de données** est verrouillée par 29 scénarios SQL + l'étape 6 d'intégration PDO et

la migration MariaDB, rejoués automatiquement à chaque push sur MySQL 8.0 et MariaDB 11.8 ;

• l'**application complète** (57 cas fonctionnels `F-00`...`F-56`, dont le bilinguisme intégral FR/EN, le fuseau horaire local sans tiers, les confirmations en 2 étapes, les tableaux mobiles `data-label`, les mentions légales LCEN et les outils de conservation) est couverte par les 15 jobs de CI ;

• la **recette manuelle humaine** dispose de suites actualisées et allégées ([`docs/13-fiches-recette-uc.md`](13-fiches-recette-uc.md) et [`docs/13-suivi-recette-uc.csv`](13-suivi-recette-uc.csv), 164 scénarios + 36 couples = 200 lignes `NON JOUÉ` à dérouler sur navigateur réel et sur la base de production LineServ pendant une fenêtre pré-démo autorisée, avec restauration obligatoire de cette même base à l'état de démonstration avant la démo ; les tests responsive multi-largeurs et les tests SQL restent automatisés, `minishop_test` étant réservé à la CI) ;

• les copies versionnées de ce document dans `livrables/{html,pdf,docx}/02-document-tests-validation.*` se régénèrent avec `python3 scripts/md_to_{html,pdf,docx}.py`.